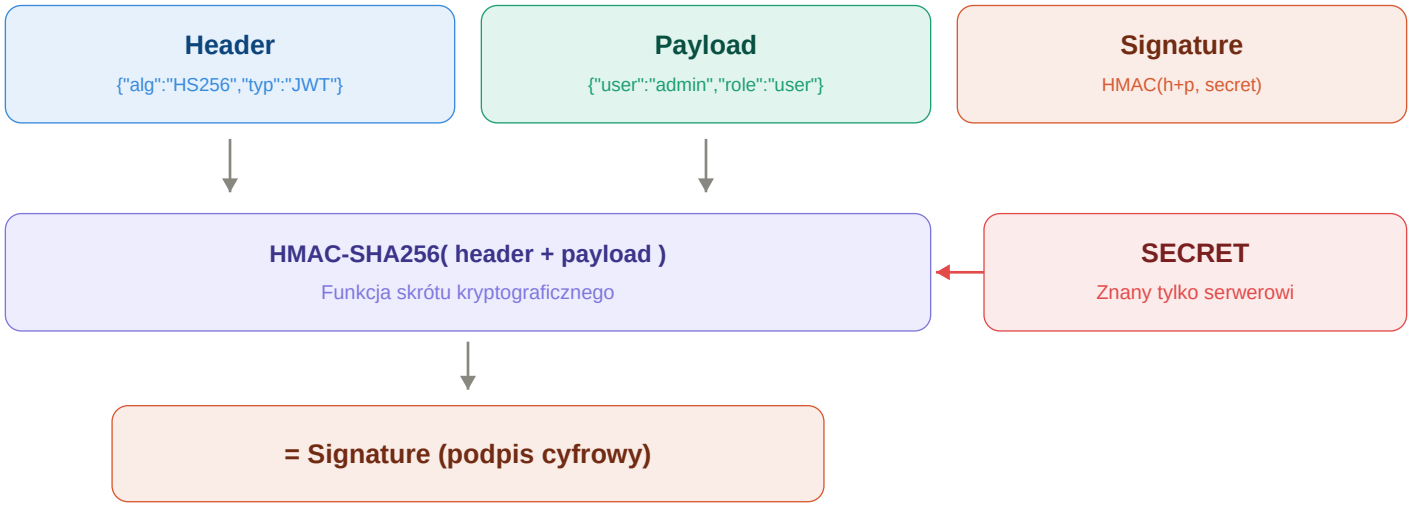
Uwierzytelnianie JWT

Struktura tokena, rola sekretu, weryfikacja podpisu i atak alg:none

1. Struktura tokena JWT

Token JWT to trzy cz■■ci zakodowane w Base64, oddzielone kropkami:



Bez znajomo■ci SECRET nie da si■ wygenerowa■ poprawnego podpisu.
Zmiana payload → inny hash → podpis si■ nie zgadza → serwer odrzuci token.
SECRET nigdy nie powinien trafi■ do klienta, frontendu ani repozytorium kodu.

2. Token z weryfikacj■ vs bez weryfikacji

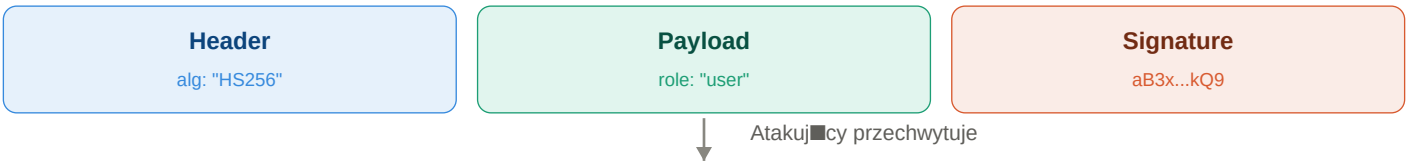
Co to daje atakuj■cemu?

Bez weryfikacji podpisu atakuj■cy mo■e zmieni■ dowolne pole w payload:
user_id, role, email, exp — i uzyska■ dost■p do cudzych kont lub uprawnie■ administratora.

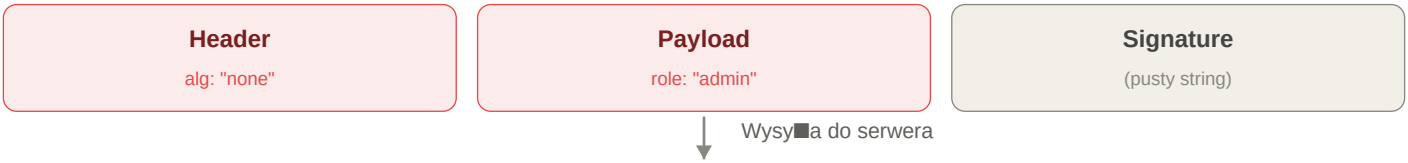
3. Atak alg: none

Specyfikacja JWT dopuszcza algorytm "none" (token bez podpisu). Podatna biblioteka czyta algorytm z nag■ówka tokena zamiast z konfiguracji serwera — atakuj■cy mo■e to wykorzysta■.

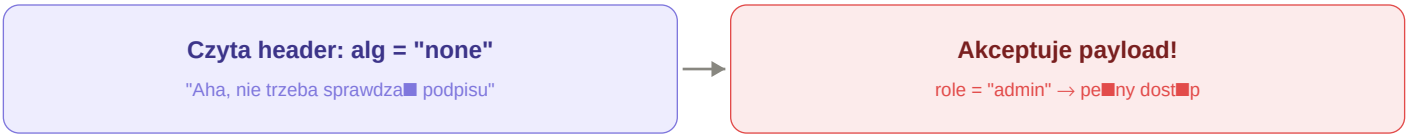
Krok 1: Oryginalny token



Krok 2: Atakuj■cy zmienia header i payload



Krok 3: Podatny serwer




```
eyJhbGciOiJub25lIn0.eyJyb2xlIjoiYWRtaW4ifQ.
```

Dlaczego to dzia■a?

Biblioteka JWT ufa nag■ówkowi tokena
Algorytm bierze z tokena, nie z konfiguracji serwera

Poprawna obrona
Wymuszaj algorytm po stronie serwera

---

4. Dobre praktyki zabezpieczenia JWT

- **Wymuszaj algorytm po stronie serwera**
  Nigdy nie pozwalaj, ■eby algorytm by■ brany z nag■ówka tokena. Jawnie ustaw np. HS256 lub RS256 w konfiguracji biblioteki.
- **Odrzucaj alg: none**
  Upewnij si■, ■e biblioteka JWT jawnie odrzuca algorytm "none". Niektóre maj■ to domy■lnie, inne nie.
- **Zawsze weryfikuj podpis**
  Ka■dy token przychodz■cy od klienta musi mie■ zweryfikowany podpis przed odczytaniem payload.
- **Chro■ secret**
  Secret klucz nie powinien trafi■ do kodu ■ród■owego, repozytorium, ani frontendu. Przechowuj go w zmiennych ■rodowiskowych lub secret managerze.
- **Sprawdzaj exp (expiration)**
  Weryfikuj czas wyga■ni■cia tokena. Krótki czas ■ycia tokena ogranicza okno ataku.
- **Waliduj claims**
  Weryfikuj issuer (iss), audience (aud) i inne claims — nie tylko podpis.